

CISM Domain 2

Information Security Risk Management

Consolidated study notes from the topics discussed in this chat, including the concepts and doubts raised during the session.

How to use these notes

These notes follow the sequence covered in the conversation. Each topic is summarized from the explanations already discussed. They are designed for quick revision and exam-oriented recall.

Core risk-management flow

Identify risk → Analyze vulnerabilities and gaps → Assess risk → Treat risk → Assign ownership → Monitor and report.

1. Risk Management Frameworks

A framework provides a structured, repeatable approach to identifying, assessing, treating and monitoring risk.

ISO/IEC 27001: ISMS requirements.

ISO/IEC 27005: Information security risk management.

ISO/IEC 31010: Risk assessment techniques.

NIST SP 800-37: Risk Management Framework and system-level security/privacy risk lifecycle.

NIST SP 800-39: Managing information security risk at an organizational level.

COBIT 2019: Governance and management of enterprise information and technology.

Risk IT: IT-related risk management.

RIMS Risk Maturity Model: Risk-management maturity.

CISM point: Select an appropriate framework and adapt it to business, regulatory, operational and organizational circumstances. Do not blindly apply one framework.

2. Risk Identification

Risk identification asks: **What could happen, to what, and because of what?**

Identify the asset, threat actor, threat, vulnerability and potential consequence.

Example: Customer database + cybercriminal + ransomware + unpatched server + service disruption/data loss.

A risk scenario should connect the technical event to business impact. Identification is not the same as assessment: identification asks what could go wrong; assessment asks how likely and damaging it would be.

3. Vulnerability and Control Deficiency Analysis

A **vulnerability** is a technical or environmental weakness that can be exploited. Examples: unpatched software, weak authentication, broken access control, excessive privileges and cloud misconfiguration.

A **control deficiency** is a missing, inadequate or ineffective expected control. Example: a required quarterly privileged-access review is not performed.

Gap analysis: compare the current state with the required or desired state. Example: MFA is required for all critical applications, but only 80% have it, creating a 20% gap.

Discovery methods include vulnerability scanning, penetration testing, control-gap analysis and third-party/vendor assessments. A POA&M records the finding, owner, corrective action, milestones, due date and status.

4. Risk Assessment and Analysis

Risk assessment determines how serious an identified risk is. The two main factors are:

Likelihood: How probable or frequent is the event?

Impact: How damaging would the event be to confidentiality, integrity, availability, finances, compliance, reputation or operations?

A common simplified model is **Risk ≈ Likelihood × Impact**. Organizations define their own risk scales and matrix;

there is no single universal matrix.

Qualitative assessment: High/Medium/Low or similar descriptive ratings.

Quantitative assessment: numerical probabilities, financial values or expected loss. Example: ■1 crore potential loss × 20% annual probability = ■20 lakh expected annual loss.

Inherent risk: risk before considering controls.

Residual risk: risk remaining after controls or treatment.

5. Risk Treatment

Risk treatment answers: **What should we do about the risk?**

Avoid: stop the activity that creates the risk.

Mitigate/reduce: implement controls to reduce likelihood and/or impact.

Transfer/share: shift some consequences to another party, such as through cyber insurance or contracts. The underlying risk does not disappear.

Accept: consciously retain the risk because it is within acceptable limits and the authorized risk owner agrees.

Multiple treatment options may be combined. Treatment is the decision; controls are the mechanisms used to implement it.

6. Risk Ownership vs Control Ownership

The **risk owner** is accountable for the risk and the decision to avoid, mitigate, transfer, accept or escalate it. This is commonly a business or management role.

The **control owner** is responsible for ensuring that a particular control is designed, implemented and operating effectively. Example: the IAM team may own MFA operations.

The security team may identify, assess, recommend, implement or validate controls without automatically owning the business risk. One person may hold both roles in some organizations, but the responsibilities remain conceptually different.

7. Risk Acceptance and Escalation

Residual risk should be compared with the organization's risk tolerance.

If residual risk is within tolerance, the authorized risk owner may accept it. If it exceeds tolerance, additional treatment or escalation is required.

Risk appetite: amount of risk the organization is generally willing to take.

Risk tolerance: acceptable boundary or variation for a particular risk or objective.

Risk capacity: maximum amount of risk the organization can withstand before its viability is threatened.

Risk acceptance is an informed business decision, not simply a security-team decision.

8. Risk Monitoring and Reporting

Risk management is continuous. Monitor whether threats, vulnerabilities, business conditions, controls, treatment plans or residual risk have changed.

Example: a risk previously rated Medium may become High after a new threat campaign, increased internet exposure or reduced control coverage.

Reporting should focus on information management needs for decisions, not just raw technical counts. Instead of reporting only the number of vulnerabilities, report which critical business services have risk above tolerance, who

owns it and what decision is needed.

9. KRI vs KPI

KRI, Key Risk Indicator: indicates risk exposure or a change in risk. Example: number of critical internet-facing vulnerabilities or privileged accounts without MFA.

KPI, Key Performance Indicator: measures performance against an objective or process target. Example: percentage of critical vulnerabilities remediated within the SLA.

A good KPI does not automatically mean risk is low. A program may perform well while underlying business risk remains high.

10. KGI vs KPI

KPI: measures how well an activity or process is being performed.
Example: 98% of employees completed security training.

KGI, Key Goal Indicator: measures whether the desired outcome or goal was achieved.
Example: phishing-related incidents decreased by 40%.

Memory line: KPI = performance along the way; KGI = outcome or goal achieved.

11. Due Care vs Due Diligence

Due care: taking reasonable and appropriate actions that a responsible organization should take to protect assets.
Example: implementing MFA, patching, training and risk assessments.

Due diligence: continuously investigating, reviewing, testing, auditing and verifying that security measures remain appropriate and effective.

Memory line: Due care = do what should be done; due diligence = check and maintain that it is being done properly.

12. Gap Assessment vs Risk Assessment

Gap assessment: What should we have compared with what we actually have? It focuses on controls, capabilities, standards, policies and requirements.

Risk assessment: What could go wrong, how likely is it, and what would the impact be? It focuses on risk exposure.

A gap can contribute to risk, but a gap is not automatically a High risk. Business context, likelihood and impact determine the risk level.

13. Strategy vs Roadmap

Strategy: the direction, objectives, priorities and overall approach for achieving a business or security goal. Example: shift AppSec left, automate testing and integrate security into the SDLC.

Roadmap: the time-based sequence of initiatives and milestones used to execute the strategy. Example: first automate DAST, then expand SAST/SCA orchestration, then introduce advanced testing capabilities.

Usually, strategy comes before roadmap: direction first, execution sequence second.

14. Data Classification vs Data Sensitivity

Data sensitivity: how much harm could result from improper access, disclosure, alteration or loss.

Data classification: the label or category assigned to data to determine how it must be handled and protected. Example categories may include Public, Internal, Confidential and Restricted.

Sensitivity informs classification. Classification then drives access, storage, sharing, encryption, retention and disposal requirements. Classification levels are defined by the organization and its legal, regulatory and business context.

15. Safeguards vs Countermeasures

A **safeguard** is a broad protective measure used to reduce risk, such as encryption, MFA, firewalls, backups and awareness training.

A **countermeasure** is a measure intended to counter a particular threat or attack, such as email filtering against phishing or EDR against ransomware.

A countermeasure can also be a safeguard. Memory line: safeguard protects; countermeasure counters.

16. Risk Register and Risk Documentation

A **risk register** is the central record of identified risks and their management status.

Typical fields include risk scenario, affected asset/process, threat and vulnerability, likelihood, impact, rating, existing controls, treatment plan, risk owner, residual risk, status and review date.

A risk register supports traceability, accountability and reviewability. It is different from a vulnerability database: a vulnerability list records technical weaknesses, while a risk register records business risks, ownership and treatment decisions.

17. Risk Prioritization

Risk prioritization determines which risks should be addressed first when resources are limited.

Consider likelihood, impact, business criticality, regulatory/legal requirements, risk appetite/tolerance, cost and treatment feasibility.

Do not prioritize solely by CVSS or the number of vulnerabilities. A lower-CVSS issue affecting a payment system may represent greater business risk than a higher-CVSS issue on an isolated test server.

18. Risk Treatment Plan

A risk treatment plan describes how a prioritized risk will be managed.

It may include the treatment decision, required actions, controls, responsible owner, timeline, budget/resources, target residual risk, milestones, status and monitoring approach.

Example: mitigate an API authorization risk by fixing the flaw, performing security testing, deploying additional protection, assigning the application team, setting a deadline and validating the fix. Residual risk must then be reassessed.

19. Cost-Benefit Analysis of Risk Treatment

Before implementing a control, consider whether the cost is justified by the expected risk reduction and business benefit.

Consider control cost, expected loss, risk reduction, business impact, operational impact, resources and regulatory

requirements.

An expensive control is not automatically unjustified. Legal, regulatory, safety or critical-business requirements may require treatment even when direct financial return is low. Cost-benefit analysis supports management judgment; it does not replace it.

20. Risk Response Options in Practice

Avoid, mitigate, transfer and accept are the four core response options. They can be combined.

Example: ransomware risk may be mitigated with EDR, segmentation and backups; some financial consequences may be transferred through insurance; the remaining low residual risk may be accepted by the authorized risk owner.

The response should align with business priorities, risk appetite, risk tolerance and the organization's authority structure.

21. Control Selection

Control selection means choosing controls appropriate to the specific business risk, rather than deploying controls simply because they are available.

Consider risk level, business requirements, cost, regulatory obligations, effectiveness, existing controls and risk tolerance.

Control categories discussed:

Preventive: stops or limits an event, such as MFA or a firewall.

Detective: identifies events, such as SIEM alerts or IDS.

Corrective: restores or fixes after an event, such as backup restoration.

Deterrent: discourages attempts, such as warning banners.

Compensating: alternative protection when the preferred control cannot be implemented.

22. Control Effectiveness

A control being implemented does not prove that it is effective.

Assess whether it is correctly implemented, consistently applied, operating as intended, covering the required scope, managing exceptions and reducing the intended risk.

Example: saying "EDR is deployed" is insufficient. Check whether it covers all critical endpoints, alerts are investigated and infections are being reduced.

Memory line: implemented does not equal effective.

23. Control Testing and Assurance

Control testing: verifies that a control is appropriately designed and operates effectively.

Design effectiveness: Would the control work if implemented properly?

Operating effectiveness: Does the control actually work consistently in practice?

Audit/assurance: an independent assessment that provides confidence to management that controls and processes meet defined requirements.

Example: testing MFA checks whether it is required, enabled for all privileged accounts, bypass-resistant and properly governed.

Final CISM Revision Chain

Identify: What can go wrong?

Analyze: What weakness or gap enables it?

Assess: How likely and how damaging is it?

Treat: Avoid, mitigate, transfer or accept.

Assign: Who is accountable for the risk and who operates the control?

Monitor: Has the risk changed and are controls effective?

Report: What does management need to know or decide?

High-value exam reminders

- Business risk is more important than technical severity alone.
- Risk owner and control owner are not automatically the same person.
- Risk acceptance requires appropriate authority.
- Residual risk must be compared with risk tolerance.
- Transfer does not eliminate the underlying risk.
- A control can exist without being effective.
- Gap assessment identifies missing capabilities; risk assessment determines exposure.
- Strategy gives direction; roadmap sequences execution.
- KRI measures risk exposure; KPI measures performance; KGI measures outcomes.